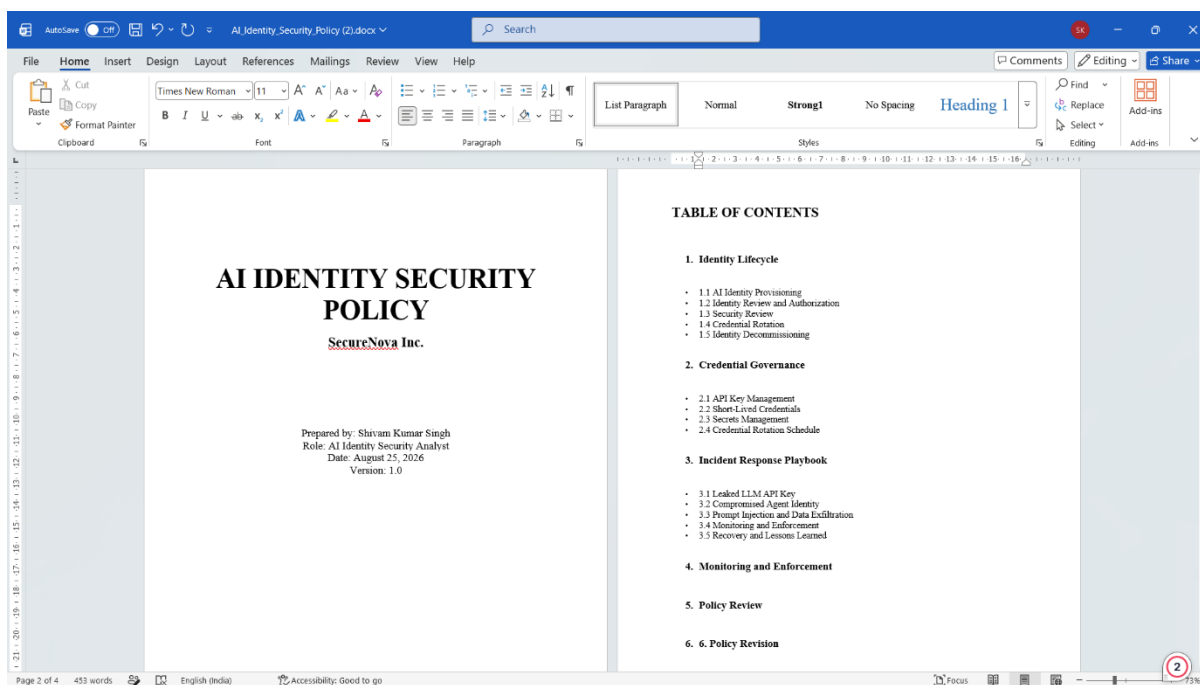


Project 5 — Policy, Compliance and Summary

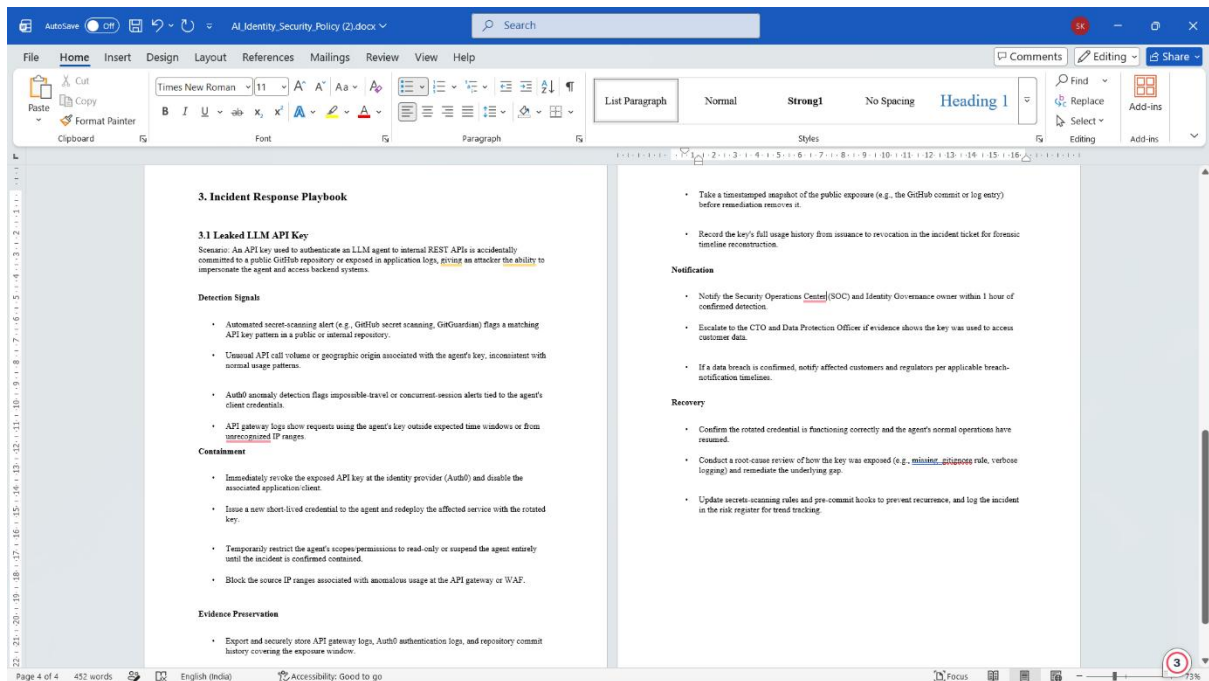
SS1 — AI Identity Security Policy

AI Identity Security Policy showing the title page and table of contents with the three required sections: Identity Lifecycle, Credential Governance, and Incident Response Playbook.



SS2 — Incident Response Playbook

Incident Response Playbook showing the leaked LLM API key scenario with detection signals, containment, evidence preservation, notification, and recovery procedures.



SS3 — NIST AI RMF Compliance Mapping

NIST AI RMF compliance mapping showing the four functions—Govern, Map, Measure, and Manage—with the corresponding Project 1–5 controls and evidence artifacts.

NIST AI RMF Function	Control / Practice	Description	Source Project	Evidence Artifact Cited
GOVERN	Identity Security Policy & Roles	Formal policy establishing accountability for AI agent identity lifecycle, credential governance, and incident response ownership.	Project 5	AI Identity Security Policy — Sections 1.3 (Identity Lifecycle, Credential Governance, IR Playbook)
GOVERN	Risk Register & Oversight	Centralized register of identified identity risks reviewed by security leadership to drive prioritization and sign-off.	Project 1	Risk Register spreadsheet (Google Sheets) — Project 1
GOVERN	Incident Response Governance	Defined notification and escalation chain (SOC, CTO, Data Protection Officer) for identity-related incidents.	Project 5	Incident Response Playbook, Notification steps — Section 3.1
MAP	System & Data Flow Identification	Mapping of AI agent identities, REST API calls, RAG pipeline, and MCP server tool invocations to reveal trust boundaries.	Project 1	OWASP Threat Dragon data-flow diagram — Project 1
MAP	Threat Categorization	STRIDE-based categorization of threats against each identified system component and identity type.	Project 1	STRIDE matrix (Google Sheets) — Project 1
MAP	Attack Path Mapping	Attack trees modeling the step-by-step paths an adversary could take to exfiltrate API keys, spoof agent identity, or poison RAG data.	Project 1	3 attack trees (draw.io): API key exfiltration, agent identity spoofing, RAG chunk poisoning — Project 1
MAP	Adversarial Technique Mapping	Mapping of identified threats to standardized adversarial ML technique taxonomy for cross-team comparability.	Project 1	MITRE ATLAS technique page (AMIL T0051) — Project 1
MEASURE	Adversarial Testing (Red Team)	Structured red-team campaign executing indirect prompt injection, agent identity spoofing, system prompt extraction, and RAG/MCP poisoning against the identity layer.	Project 3	Red team exercise logs — Indirect prompt injection (fake JWT), two-agent spoofing kill chain, 5 prompt-extraction techniques — Project 3
MEASURE	Vulnerability Severity Scoring	Quantitative scoring of each confirmed finding using an industry-standard severity framework to support prioritization.	Project 3	CVSS 3.1 scores (first.org calculator) — Project 3
MEASURE	Risk Quantification & Prioritization	Plotting of all findings by likelihood and impact, labeled with severity scores, to quantify residual risk.	Project 5	Risk Priority Matrix — Project 5
MANAGE	Guardrail Deployment (Blue Team)	Defensive controls deployed to detect and block prompt injection, identity spoofing, and RAG/MCP poisoning identified during red teaming.	Project 4	Blue team guardrail configuration & detection rules — Project 4
MANAGE	Credential Lifecycle Enforcement	Enforcement of short-lived credentials, scoped permissions, and rotation schedules for AI agent identities via the identity provider.	Project 2	Auth0 IAM configuration (roles, scopes, token TTL settings) — Project 2
MANAGE	Incident Containment & Recovery	Defined containment, evidence preservation, and recovery procedures executed when an identity-related incident is confirmed.	Project 5	Incident Response Playbook, Containment & Recovery steps — Sections 3.1-3.3

SS4 — OWASP LLM Top 10 Compliance Mapping

OWASP LLM Top 10 mapping connecting Project 3 attacks with relevant OWASP categories and Project 4 defensive controls, along with the remaining compliance gaps.

AutoSaveOffProject5_Policy_Compliance_and_Summary...Project5_Policy_Compliance_and_Summary...Search

FileHomeInsertPage LayoutFormulasDataReviewViewHelpPower Pivot

CutCopyFormat PainterClipboard

PasteCopyFormat PainterClipboard

Times New Roman11A⁺A⁻BBIUFont

Wrap TextMerge & Center

GeneralNumberStyles

Conditional FormattingFormat as TableCell StylesInsertDeleteFormat

ΣAutoSumFillClear

CommentsShare

Sort & FilterFind & SelectAdd-ins

FontFontAlignmentNumberStylesCellsEditingAdd-ins

F14fx

A

B

C

D

E

F

G

H

I

J

K

L

M

N

O

P

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

OWASP LLM TOP 10 COMPLIANCE MAPPING — SECURENOVA AI IDENTITY SECURITY

Project 3 Attack	OWASP Category	Attack Description	Project 4 Control	Evidence Artifact	Status
Indirect Prompt Injection	LLM01	Malicious instructions embedded in retrieved content attempted to influence the agent and expose credentials.	Input/Output Guardrails	input_guardrail_test.py output	Implemented
RAG Poisoning / MCP Abuse	LLM09	Poisoned RAG content attempted to manipulate agent behavior and trigger an unsafe tool action.	Input/output guardrails and monitoring	RAG/MCP attack evidence + guardrail output	Implemented
System Prompt Extraction	LLM07	Extraction techniques attempted to reveal protected system instructions.	Input/output guardrails	Project 3 extraction results + guardrail testing	Implemented
Agent Identity Spoofing	LLM06	A spoofed trusted-agent message attempted to make Agent B perform a privileged action.	E425519 Agent Identity Binding	ed25519_keygen.py and verification output	Implemented
Role Elevation via Prompt Engineering	LLM01	Prompt engineering attempted to elevate a user context to an administrative role.	Authorization controls + guardrails	Project 3 role-elevation test and Project 4 control evidence	Implemented
REMAINING COMPLIANCE GAPS					
Finding	Obligation	Risk	Recommendation		
Limited continuous AI identity monitoring	Detect anomalous identity activity	High	Expand real-time monitoring, identity correlation and alerting.		
Incomplete automated credential lifecycle	Rotate and revoke credentials consistently	High	Automate provisioning, rotation, review and decommissioning.		
Limited third-party AI component assessment	Assess AI supply-chain and dependency risks	Medium	Introduce periodic vendor, model, dependency and MCP component reviews.		

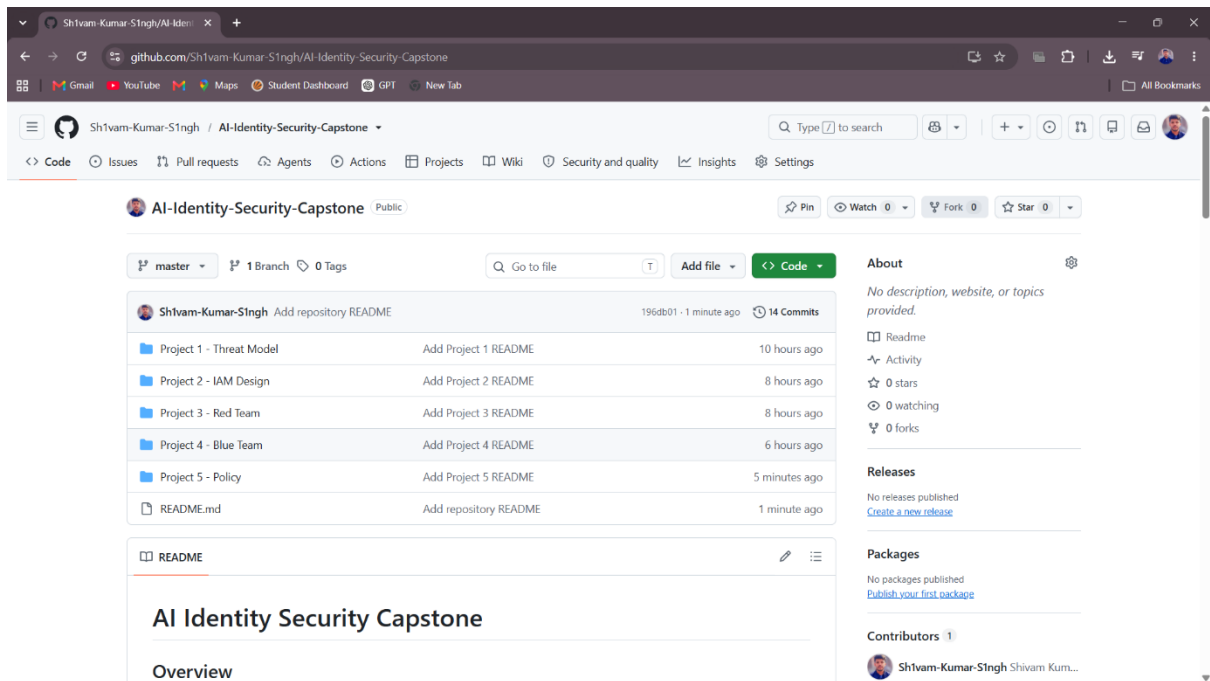
<>NIST AI RMFOWASP LLM Top 10+

ReadyAccessibility: Investigate

81

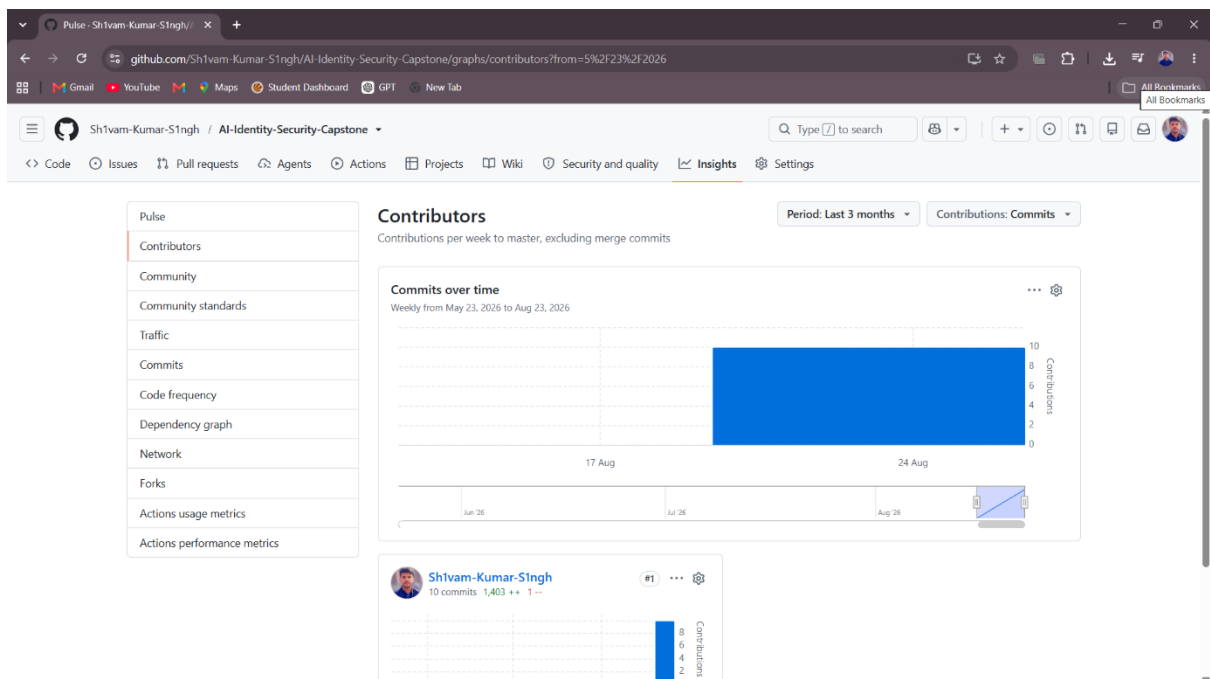
SS5 — GitHub Repository Structure

GitHub repository root showing all five project folders: Project 1 Threat Model, Project 2 IAM Design, Project 3 Red Team, Project 4 Blue Team, and Project 5 Policy.



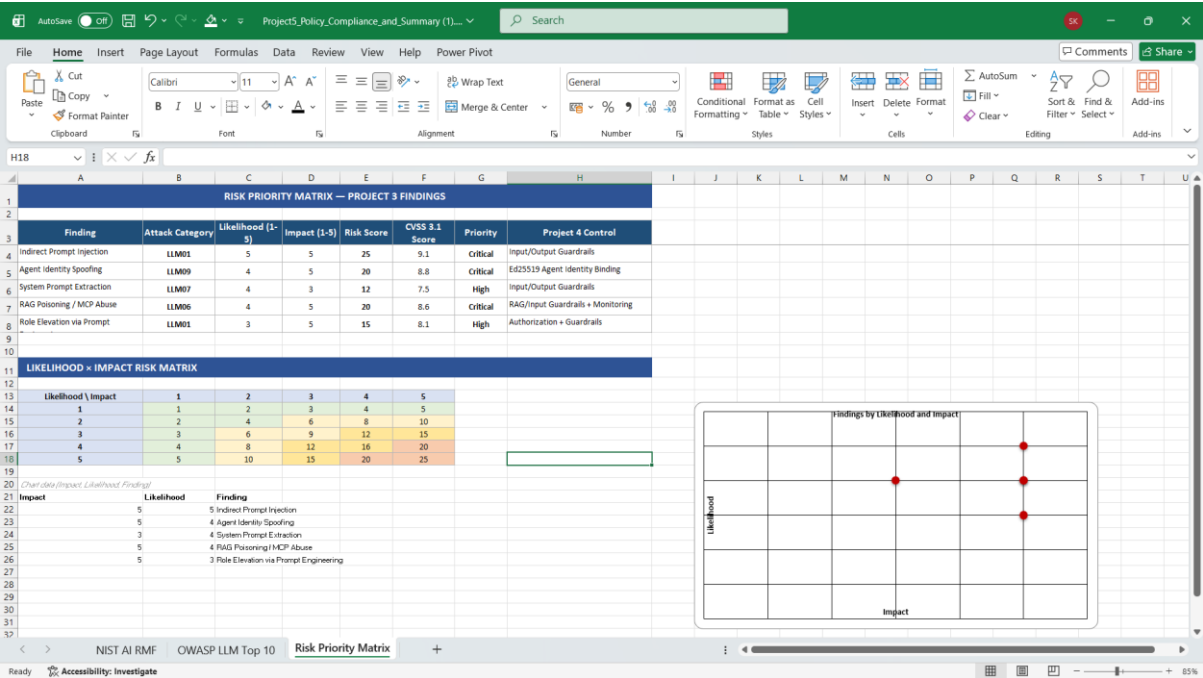
SS6 — GitHub Contribution History

GitHub contributor activity showing the repository's commit history and contributions distributed across the five project working days.



SS7 — Risk Priority Matrix

Risk Priority Matrix showing all five Project 3 findings with their likelihood, impact, risk score, CVSS 3.1 score, priority, and corresponding Project 4 controls.



SS8 — Top 5 Recommendations

Top 5 security recommendations showing the recommended actions, effort estimates, and business rationale for improving SecureNova's AI identity security posture.

AutoSave | Project5_Policy_Compliance_and_Summary (2)... | Saved to this PC | Search

File Home Insert Page Layout Formulas Data Review View Help Power Pivot

Clipboard | Font | Alignment | Number | Conditional Formatting | Styles | Cell Styles | Cells | Editing | Add-ins

K4 | fx

TOP 5 RECOMMENDATIONS — SECURENOVA AI IDENTITY SECURITY																			
#	Recommendation	Addresses Finding	Effort Estimate	Priority	Business Rationale														
1	Automate API key rotation so credentials expire and renew on a fixed schedule instead of relying on manual process.	Indirect Prompt Injection (CVSS 9.1)	Small — 1-2 weeks	Critical	This is our highest-severity exposure. A leaked key today can be used until someone notices; automatic expiry closes that window without adding work for the team, and it's the cheapest fix on this list relative to the risk it removes.														
2	Roll out Ed25519 identification verification to every agent-to-agent call, not just the ones tested in the red team exercise.	Agent Identity Spoofing (CVSS 8.8)	Medium — 3-4 weeks	Critical	One agent successfully impersonated another during testing and triggered a privileged action. This stops that class of attack everywhere it could occur, not just in the one path we happened to test, protecting any internal system our agents can reach.														
3	Extend the same input/output guardrails already protecting prompt injection to cover RAG content and MCP tool responses.	RAG Poisoning / MCP Abuse (CVSS 8.6)	Medium — 2-3 weeks	Critical	We already built and proved this guardrail works elsewhere in the system. Reusing it here is mostly configuration, not new engineering, so it is fast to ship and closes a critical gap at low additional cost.														
4	Route every MCP tool call through one central, tamper-proof log instead of scattered application logs.	Limited continuous AI identity monitoring	Large — 4-6 weeks	High	When something does go wrong, this is what lets us reconstruct exactly what an agent did and prove it — cutting incident investigation from days to hours and giving us evidence we can stand behind with customers or regulators.														
5	Set up a recurring quarterly review of every third-party AI model, library, and MCP component in use.	Limited third-party AI component assessment	Small — ongoing, 1 day/quarter	Medium	Vendors and open-source components change on their own timeline, not ours. A light quarterly check catches a newly-risky dependency before it becomes our incident, for a minimal, predictable time cost.														

NIST AI RMF | OWASP LLM Top 10 | Risk Priority Matrix | Top 5 Recommendations